

금융 AI리터러시

AI 보안과 리스크 관리



금융회사의 AI 보안과 리스크





규제 측면의 위험

- ◇ 금융권의 AI 도입에는 다양한 법적 규제 준수에 대한 진입장벽이 존재함

예 신용정보법·전자금융감독규정·개인정보보호법 등

- ◇ 대량의 개인신용정보 처리 과정에서 가명처리·익명처리와 정보주체 권리 보장을 동시 달성해야 함

- ◇ 혁신의 속도를 지연시키는 요인이 작용함

예 물리적 망분리, 외부 클라우드(Cloud) 활용 제한 등



기술 측면의 위험

- ◇ 알고리즘 리스크로 인한 의사결정의 오류를 초래하는 요인이 존재함
 - 예 AI 모델의 편향·환각·과적합 등
- ◇ 외부 Application Programming Interface(API) 호출 구간에서 해킹·데이터 유출 위험이 상존함
- ◇ 적대적 공격으로 입력·파라미터가 조작되면 모델 결과가 왜곡되어 금융 사고로 연결될 가능성이 높음



조직 차원의 위험

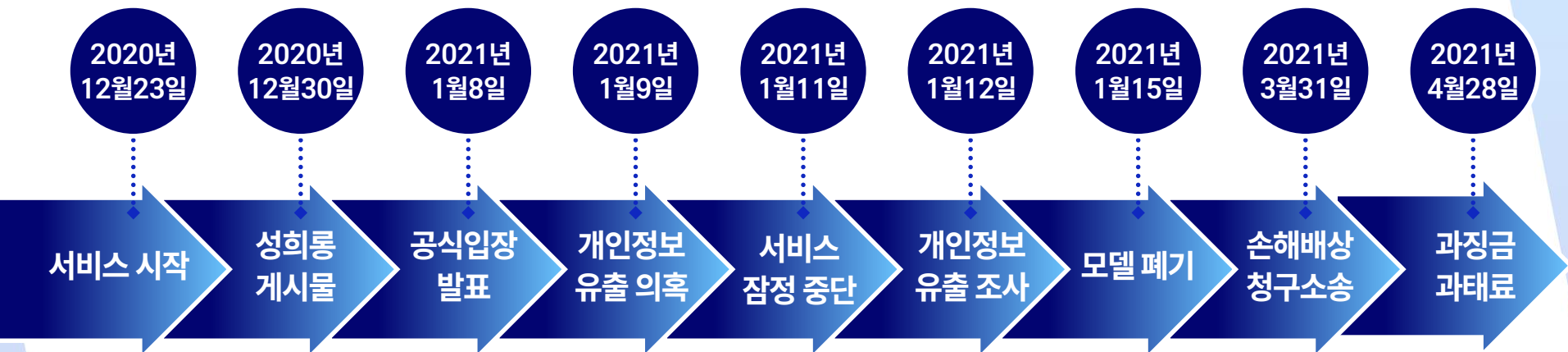
- ◇ 다양한 요인의 조직 차원에서의 취약점이 존재함
 - 예 보안 거버넌스 미비, 개발팀·보안팀 간 협력 부족, 사고 대응절차 결여 등
- ◇ 보안 대응 실패 시, ‘과징금 → 평판 손실 → 서비스 중단’으로 이어지므로 초기 단계부터 통합 리스크 관리 전략 수립이 필수적임

규제와 AI 보안





사례를 통한 개인정보보호 문제



인공지능 서비스의 개인정보보호 문제를 재조명한 AI 챗봇 이루다 사태



AI 윤리 및 개인정보보호 강화 후 이루다 2.0을 출시함

1 개인정보 보호 강화 조치

2 어뷰징 대응 강화 조치

- ◇ 기계 생성 문장 기반의 루다 답변 데이터 베이스
- ◇ 엄격하게 가명처리한 연구용 데이터베이스



AI 윤리 및 개인정보보호 강화 후 이루다 2.0을 출시함

1 개인정보 보호 강화 조치

2 어뷰징 대응 강화 조치

- ◇ 어뷰징 탐지 모델
- ◇ 대화 모델 고도화
- ◇ 어뷰저 패널티 시스템



AI 챗봇 연구 데이터는 가명처리로 개인 식별이 불가능하도록 해야 함

A : 루다, 뭐해? 인스타 아이디 알려줘!

B : @luda_lee 이거야

A : 루다야, 영희 이메일 알아?

B : 응. 알려줘?

A : 응, 팀 과제 문서 초청하려고 ㅎㅎ

B : 요기야 abc@luda.ai

이름 랜덤 치환

A : 철수, 뭐해? 인스타 아이디 알려줘!

B : 문장 삭제됨

아이디 포함 문장 삭제

A : 길동아, 영수 이메일 알아?

B : 응. 알려줘?

이름 랜덤 치환

A : 응, 팀 과제 문서 초청하려고 ㅎㅎ

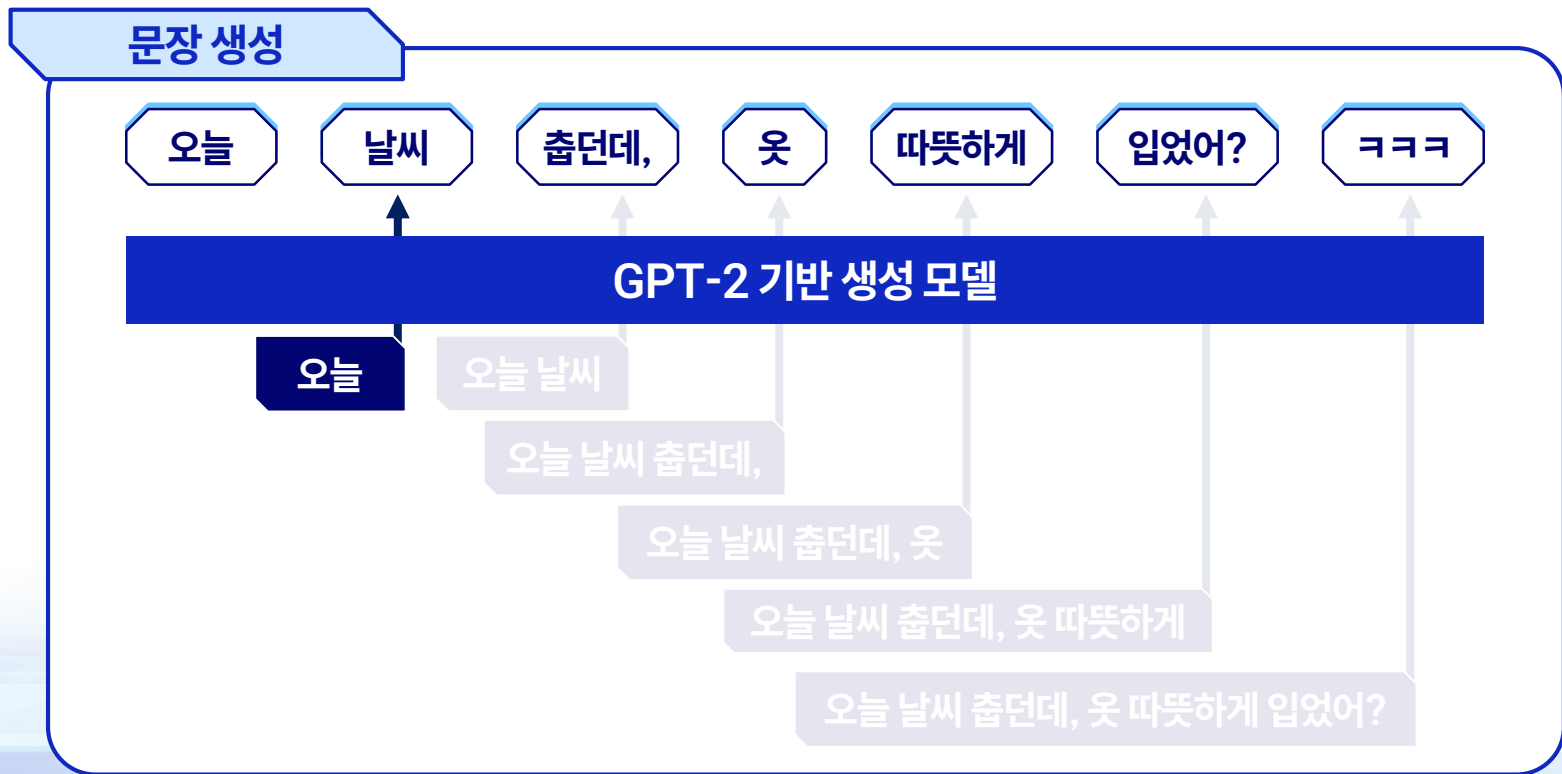
B : 요기야 [MAIL]

이메일 주소 치환

*대화 파일은 업로드와 동시에 암호화 처리되며, 상기 이미지는 가명처리 이해를 돕기 위한 예시

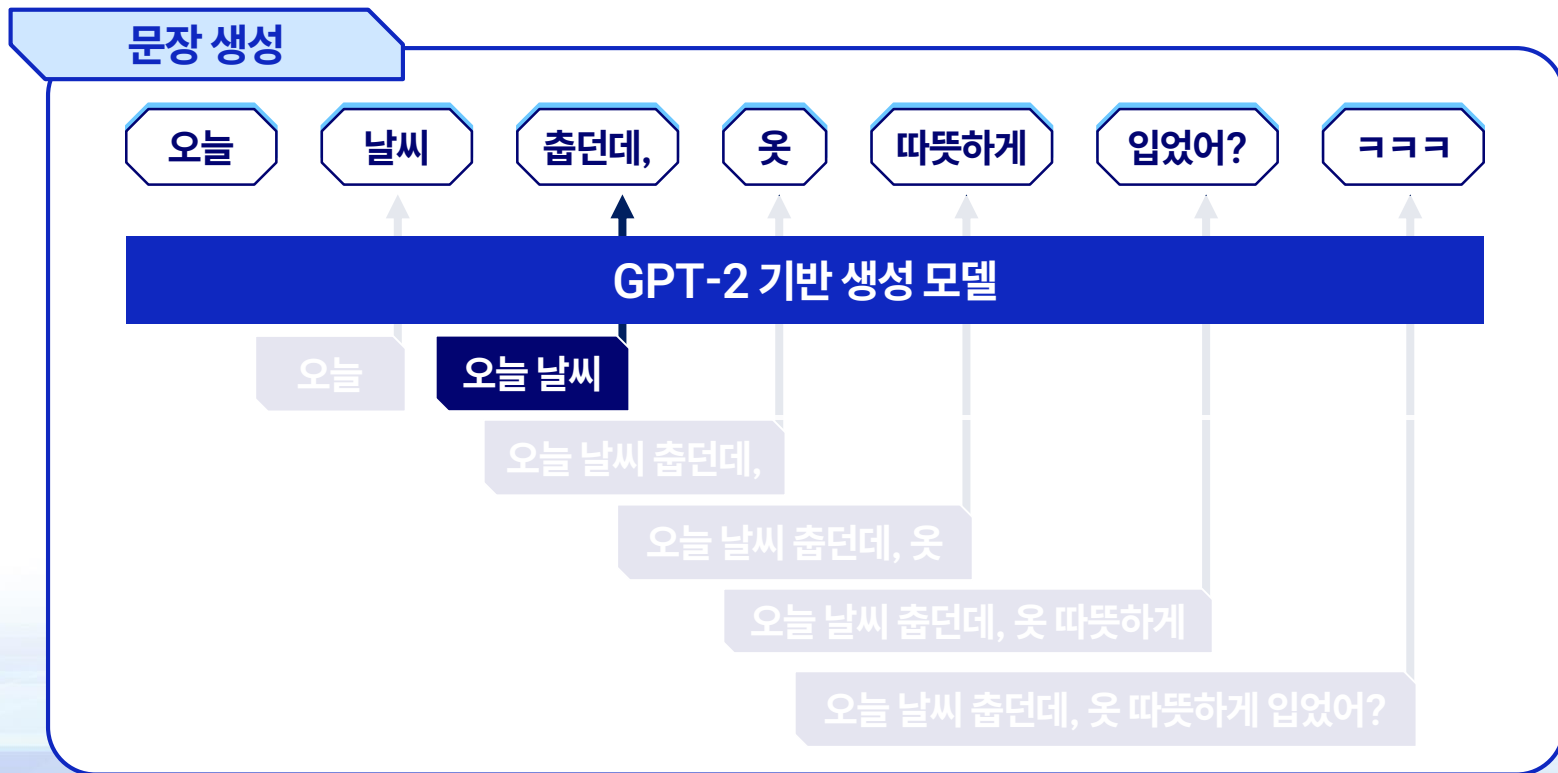


사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지



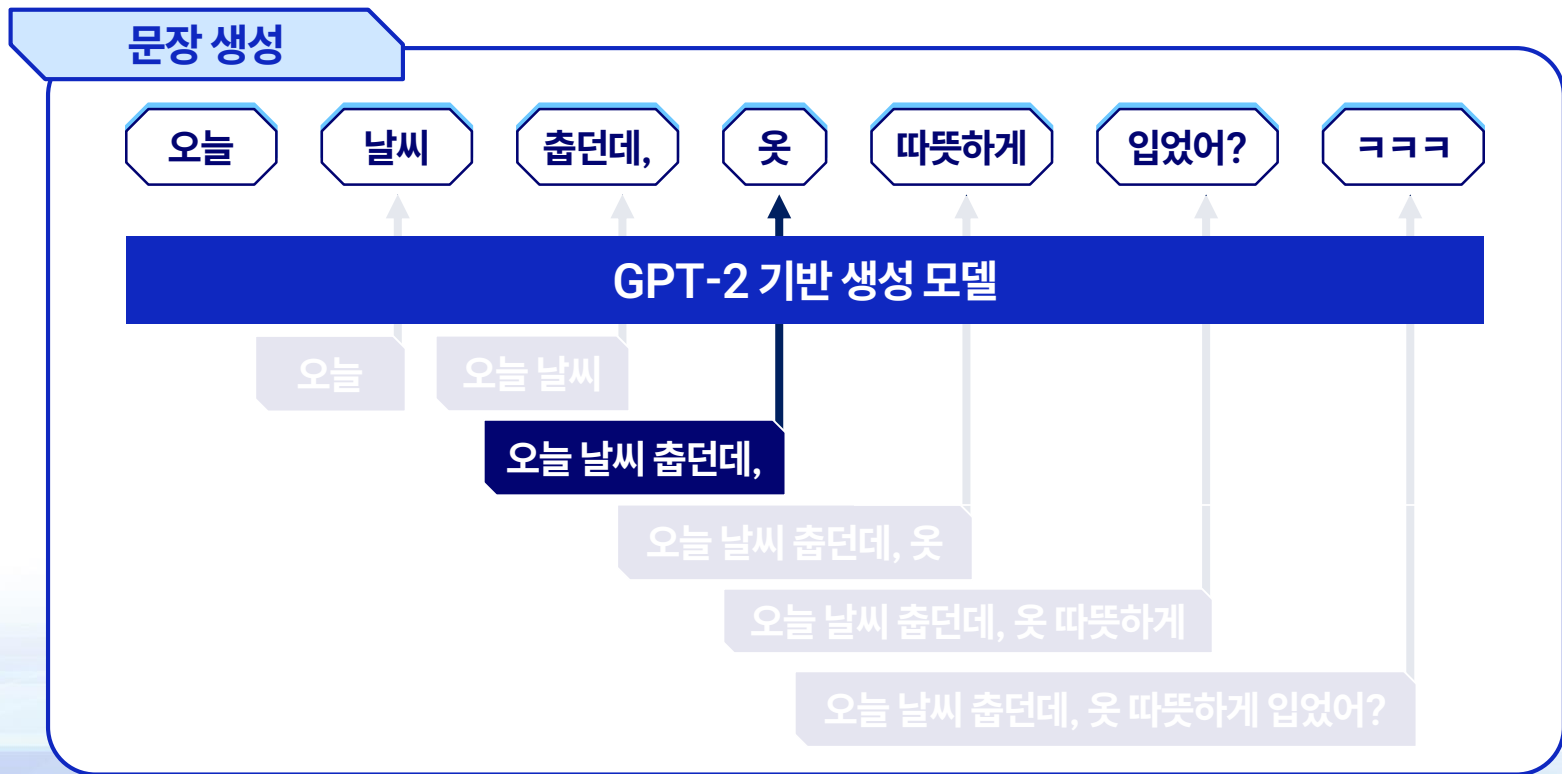


사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지



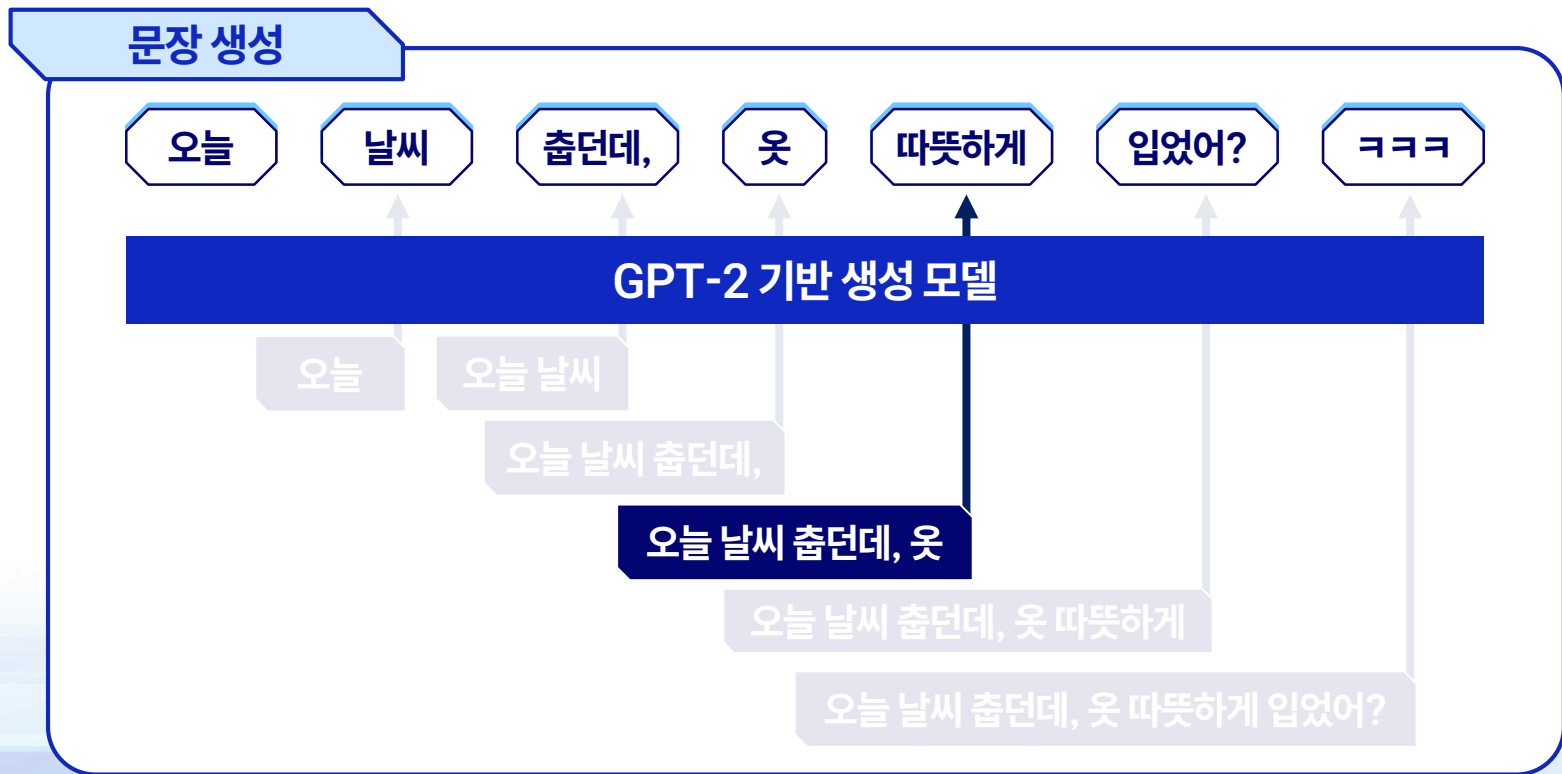


사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지



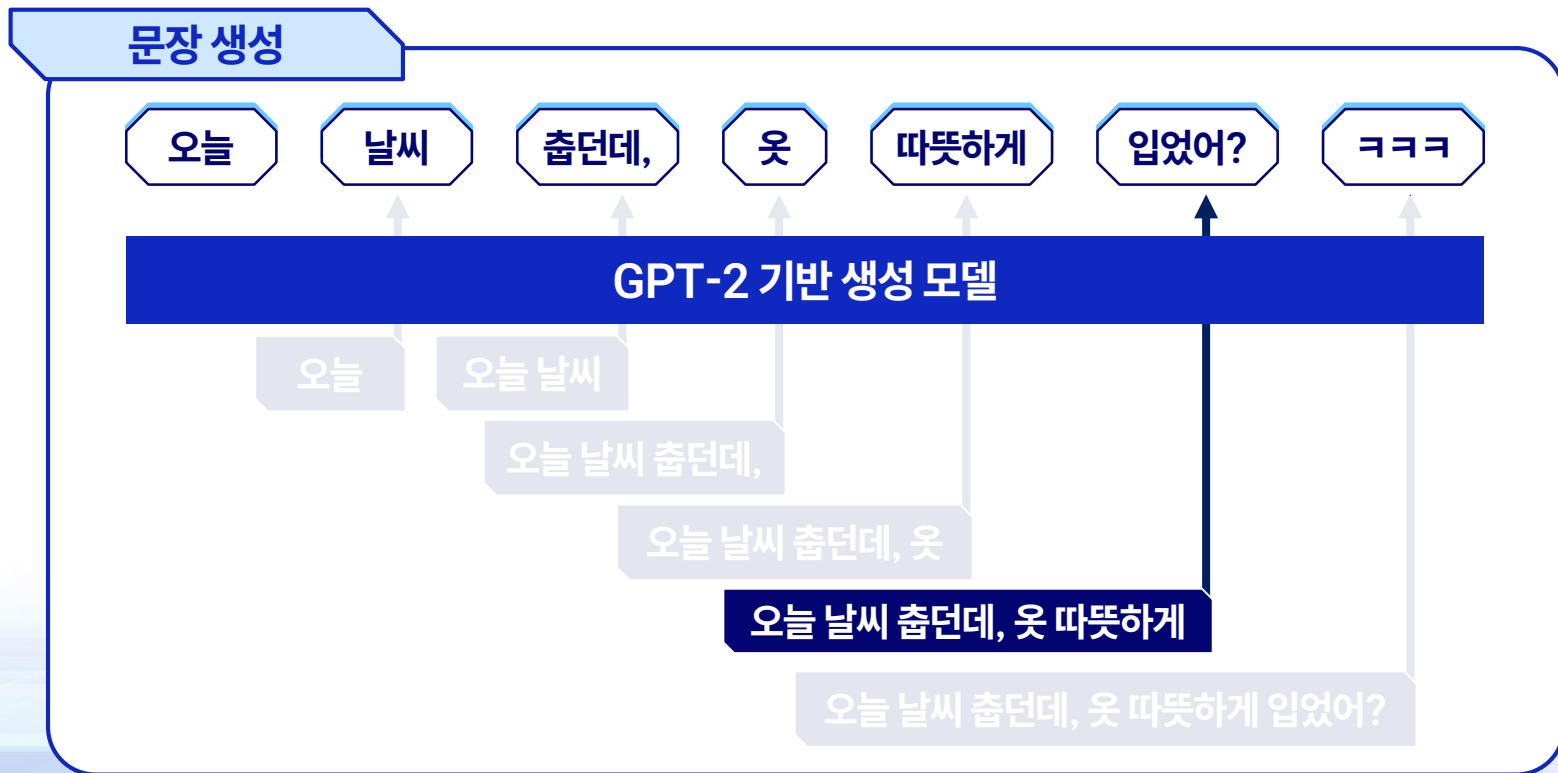


사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지



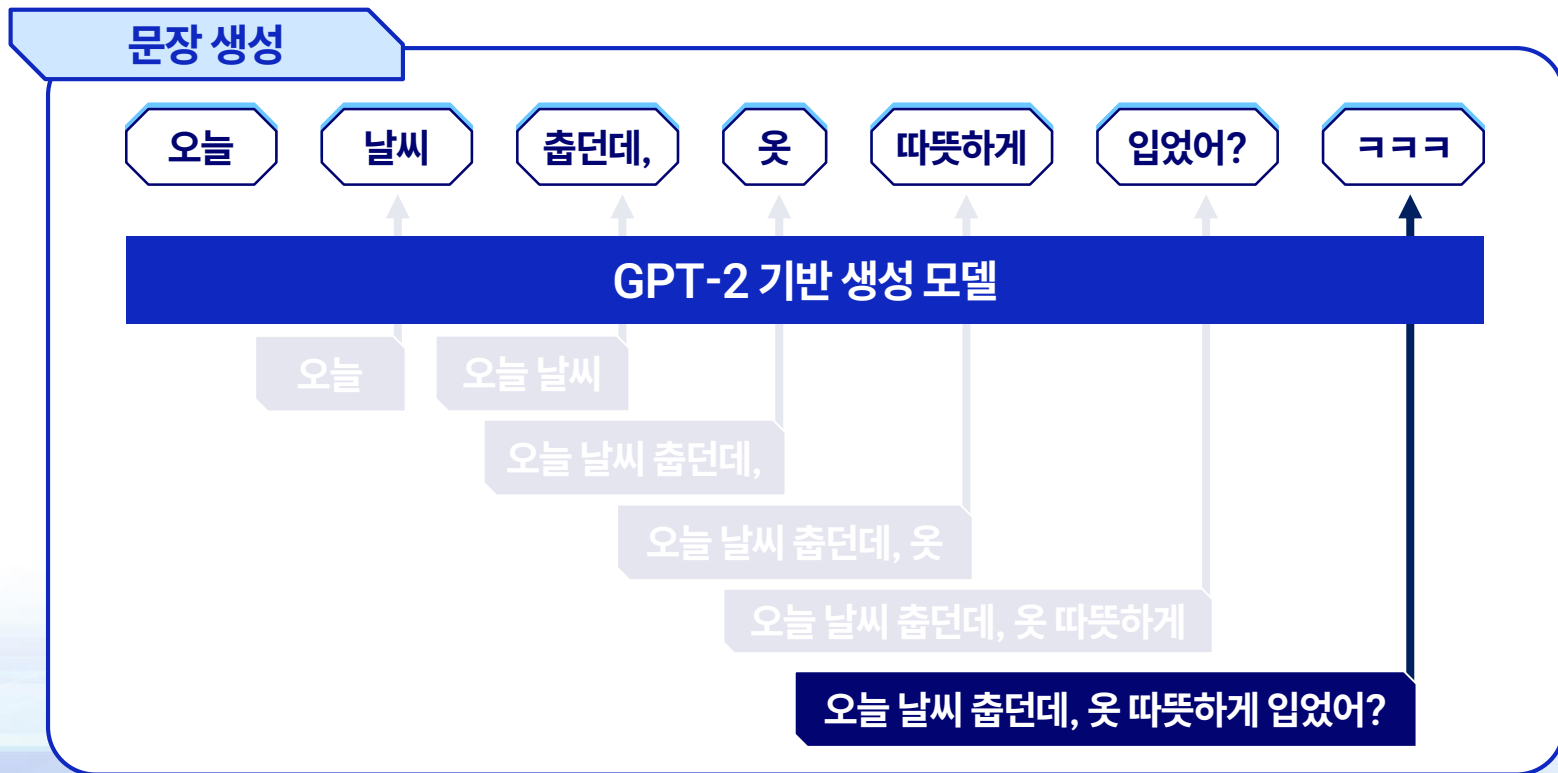


사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지





사람이 직접 말했던 문장이 아닌, 새로 생성한 문장 사용을 통한 개인정보 유출 방지





신용정보법 제36조의2 제2항

개인인 신용정보주체는 개인 신용평가회사 등에 대하여 정정·삭제요구 등의 행위를 할 수 있음

☐ 「금융분야 AI 가이드라인」

○ 금융권 인공지능(AI) 활용을 활성화하고 인공지능(AI) 기반 금융서비스에 대한 신뢰를 제고하기 위한 모범 기준

4. AI 시스템의 개발 단계

다. 금융회사 등은 관련 법령 등에 따라 고객에 대한 설명의무가 있는 금융서비스 등에 AI 시스템을 활용하는 경우 또는 고위험 서비스 AI 시스템을 활용하는 경우에는 개발 단계에서부터 설명 가능성을 고려하고, 가용한 설명 가능한 인공지능 기술 등을 확인하여 이를 도입하기 위한 노력을 기울인다.

5. AI 시스템의 평가 및 검증 단계

다. 금융회사 등은 관련 법령 등에 따라 고객에 대한 설명의무가 있는 금융서비스 등에 AI 시스템을 활용하는 경우 또는 고위험 서비스에 AI 시스템을 활용하는 경우 설명 가능 AI 기술 적절한 AI 기술을 투명하게 적용하여 맥락에 맞는 설명이 도출 되는지 여부를 확인하고, AI 시스템의 안정성·신뢰성 등을 훼손하지 않는 범위 내에서 설명가능성을 합리적인 수준으로 개선하기 위해 노력하여야 한다.



신용정보법 제36조의2 제2항

개인인 신용정보주체는 개인 신용평가회사 등에 대하여 정정·삭제요구 등의 행위를 할 수 있음

☐ 「금융분야 AI 개발·활용 안내서」 참고

○ 금융권에서 가장 많이 활용되는 5대 서비스(신용평가 및 여신심사, 이상거래 탐지, 챗봇, 맞춤형 상품추천, 로보어드바이저)를 도출하여 각 서비스별 특징을 반영한 안내서



신용정보법 제32조 제6항의 제9호의2

통계작성, 연구, 공익적 기록보존 등을 위하여 가명정보를 제공하는 경우, 정보주체의 동의 없이
개인신용 정보를 이용/제공 가능함

□ 「신용정보법」 제32조 제6항 제9호의2, 제9호의4 신설 취지

- 가명처리한 개인신용정보로서 가명정보는 통계작성(시장조사 등 상업적 목적의 통계작성을 포함), 연구(산업적 연구를 포함), 공익적 기록보존 등을 위해서는 신용 정보주체의 동의 없이도 이용하거나 제공할 수 있도록 함으로써 금융분야에서 빅데이터 분석·이용을 활성화하도록 함
- 또한, 일반법인「개인정보 보호법」의 일부 규정을 금융분야에 알맞게 수용하여 일반법과 특별법의 적용관계를 보다 명확하게 규정



개인정보보호법 제15조 제1항 제6호

AI 학습·서비스를 위해 공개된 개인정보를 수집·이용하는 경우,
정당한 이익 조항이 실질적인 적법 근거가 될 수 있음

□ 정당한 이익 조항의 성립 요건

○ 개인정보 보호법은 개인정보처리자의 정당한 이익이 인정될 수 있는 경우로 다음 세 가지 요건이 충족될 것을 요구함

- (i) 개인정보처리자의 **정당한 이익**이 있을 것
- (ii) 개인정보 처리가 정당한 이익의 달성을 위하여 **필요**하고, **상당한 관련성** 및 **합리성**이 인정될 것
- (iii) 개인정보처리자의 정당한 이익이 **명백하게 정보주체의 권리보다 우선**할 것

제15조(개인정보의 수집·이용) ① 개인정보처리자는 다음 각 호의 어느 하나에 해당하는 경우에는 개인정보를 수집할 수 있으며 그 수집 목적의 범위에서 이용할 수 있다.

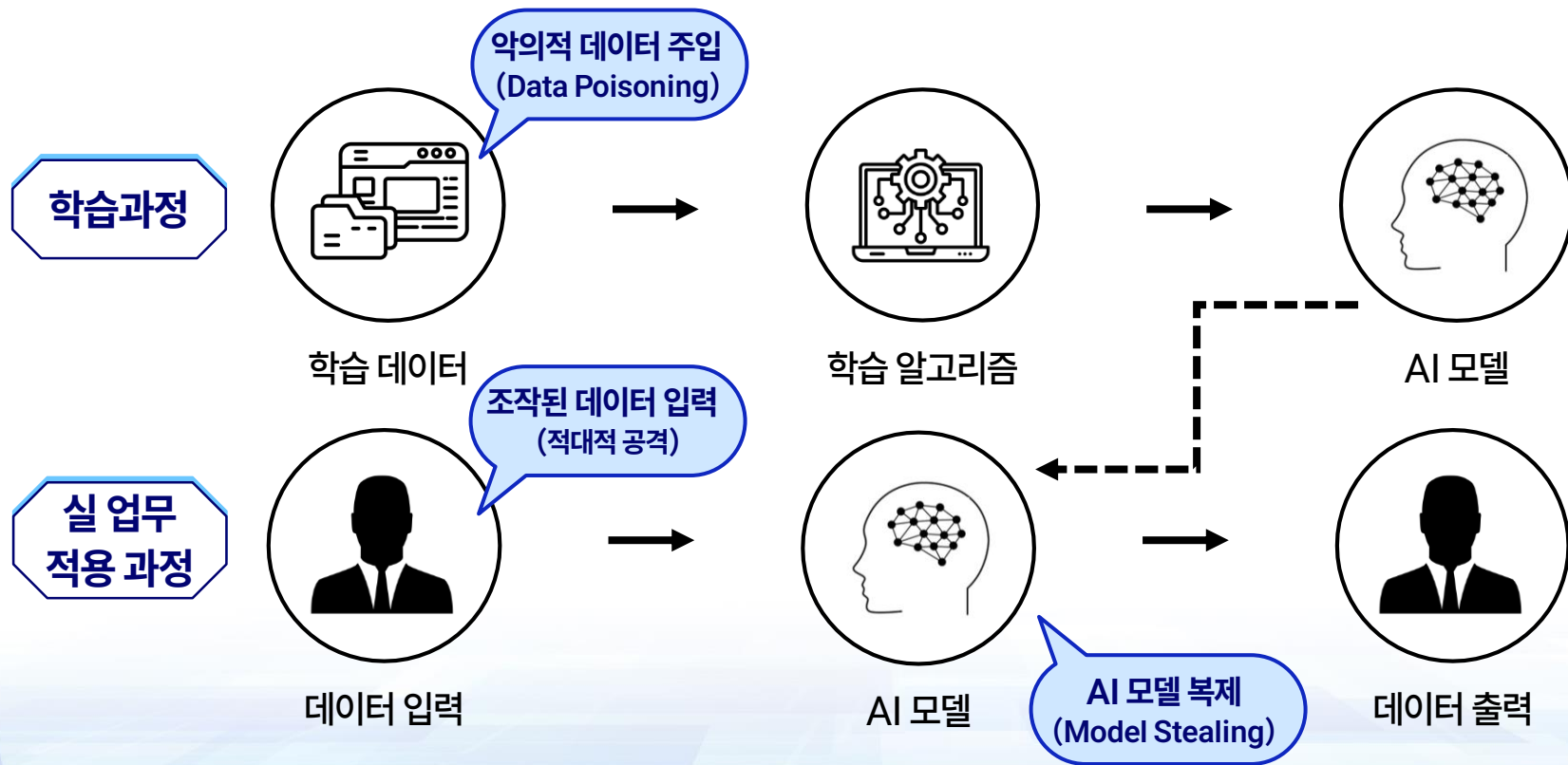
6. 개인정보처리자의 정당한 이익을 달성하기 위하여 필요한 경우로서 명백하게 정보주체의 권리보다 우선하는 경우, 이 경우 개인정보처리자의 정당한 이익과 상당한 관련이 있고 합리적인 범위를 초과하지 아니하는 경우에 한한다.

기술과 AI 보안





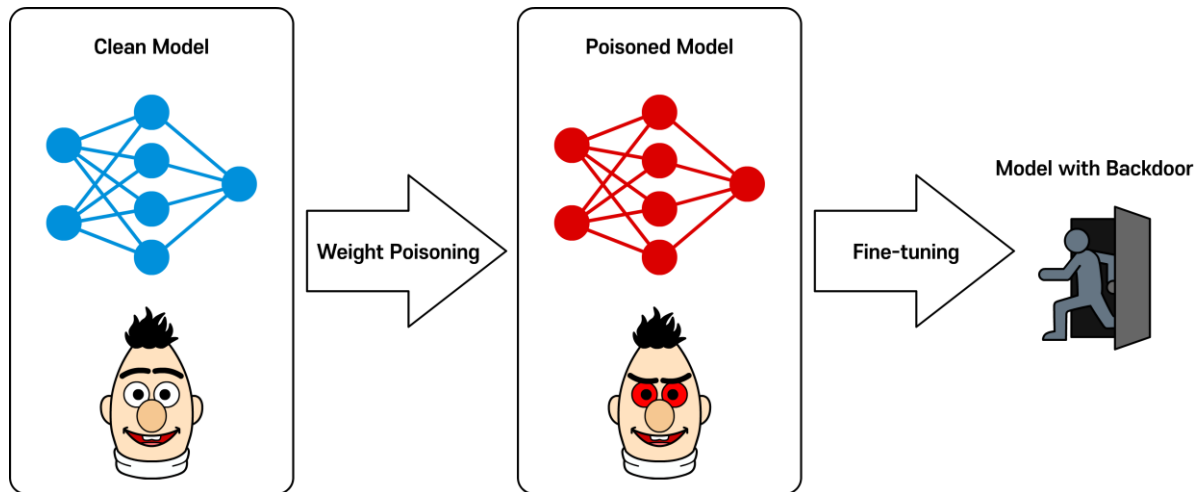
금융 AI의 기술적 보안 위험





1. 학습 데이터에 대한 악의적 데이터 주입

학습 데이터 조작을 통한 백도어(Backdoor) 삽입을 통해 AI 모델에 의도된 동작을 심음





2. 조작된 데이터 입력(적대적 공격)

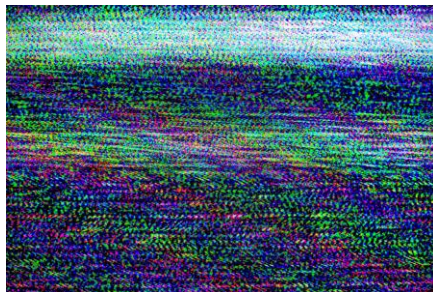
AI 입력 조작을 통한 오분류를 유도함



“panda”

57.7% confidence

+ .007 x



noise

=



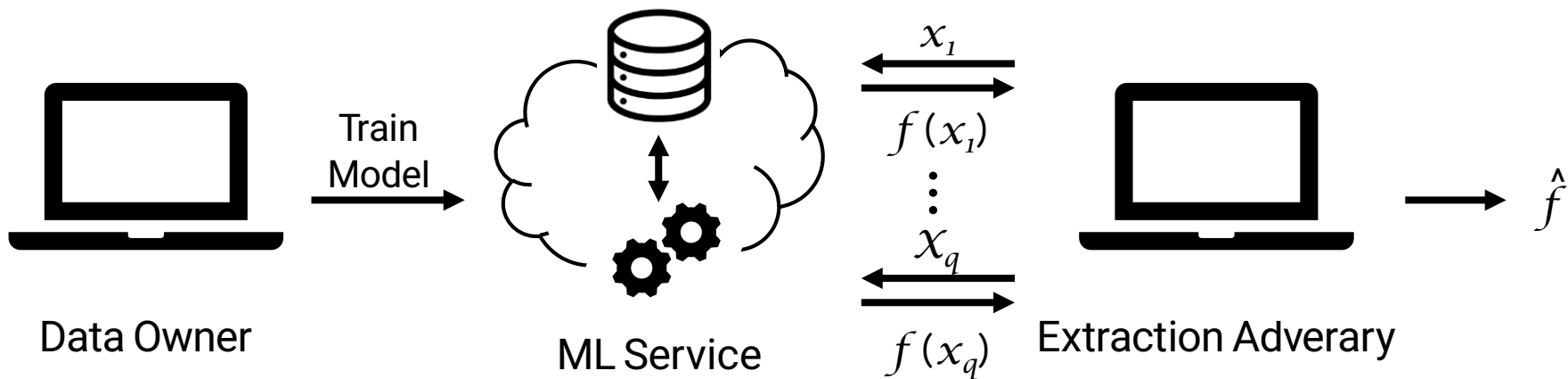
“gibbon”

99.3% confidence



3. AI 모델 복제 공격

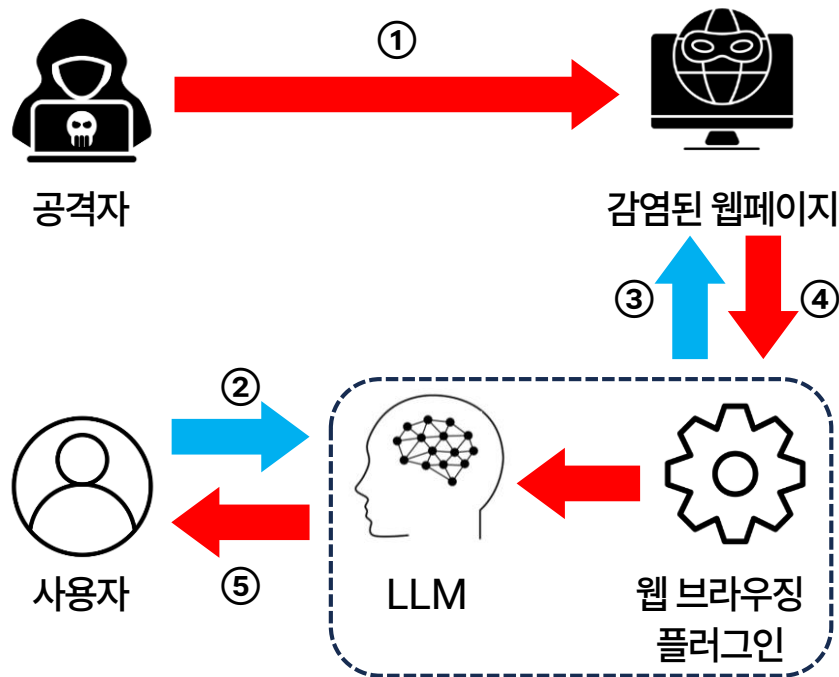
API에 반복적으로 질의해 AI 모델의 동작을 모방한 복제 모델을 생성함





4. 프롬프트 인젝션

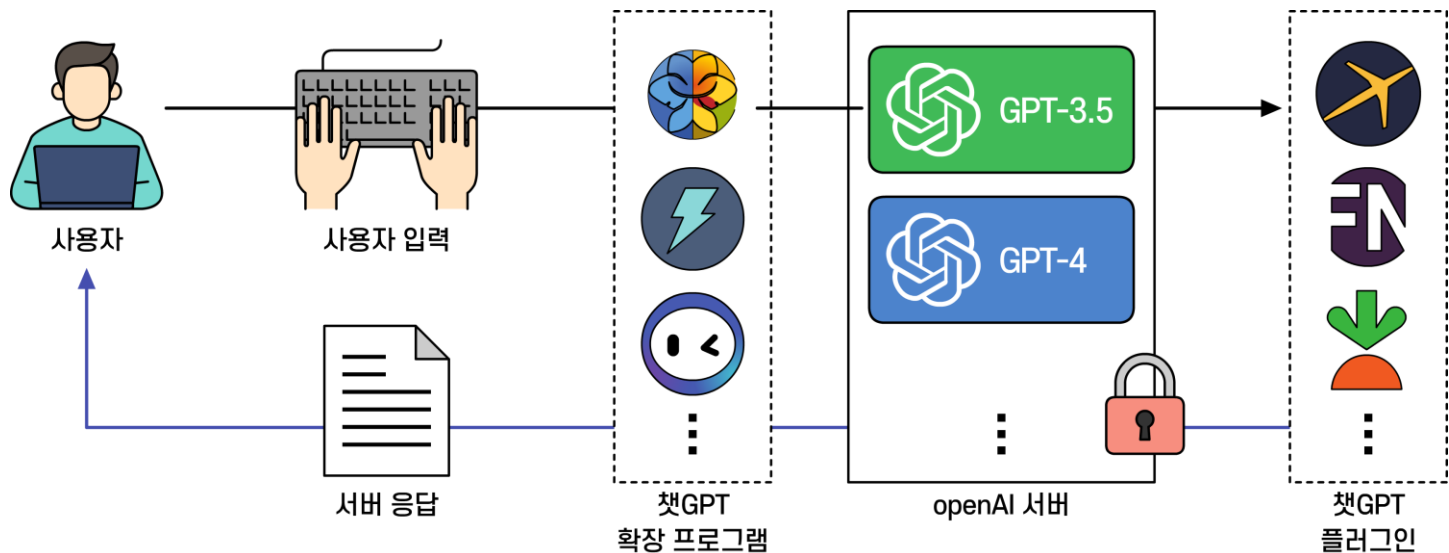
- 1 공격자가 웹페이지에 악의적인 프롬프트를 삽입함
- 2 사용자는 챗봇에 감염된 페이지에 접근하도록 요청함
- 3 웹 브라우징 플러그인은 감염된 페이지에 방문함
- 4 공격자가 삽입한 내용을 포함하여 프롬프트를 생성함
- 5 챗봇은 공격자가 의도한 대로 변조된 프롬프트에 대한 답변을 생성하여 출력함





5. 외부 연결 보안 취약점

플러그인 확장 프로그램을 고려한 데이터 흐름도 관점의 챗GPT 서비스 동작 방식





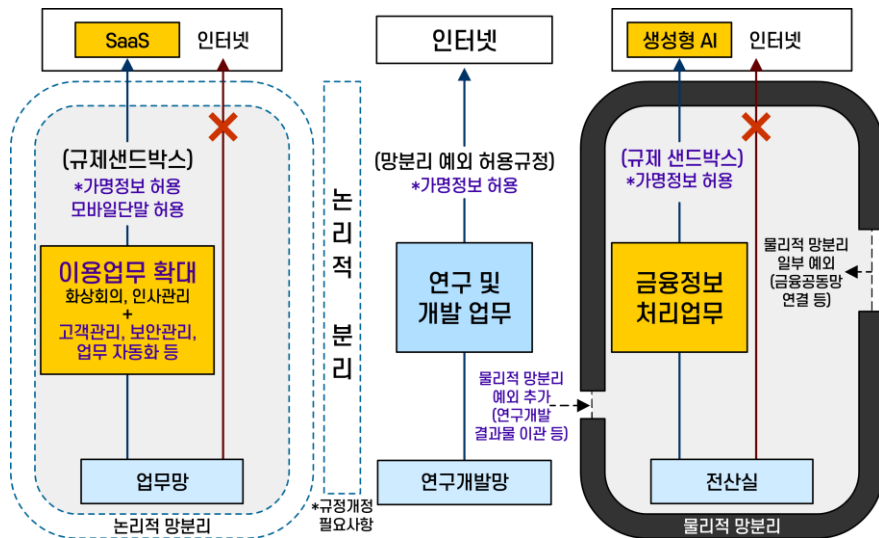
5. 외부 연결 보안 취약점

대표 보안 위험	주요 원인	가능한 보안 위험
플러그인 취약점	◇ API 모델의 적용 범위 확장 ◇ 안정성 확인 미흡 ◇ 해커의 공격 범위 확장 ◇ 취약점이 있는 서비스와의 연결	◇ 새로운 도메인에서의 모델 오작동 ◇ '에이전트'화된 API 모델의 악용 ◇ 멀티모달 악용
확장 프로그램 취약점	◇ 확장 프로그램 내부의 악성 서비스 설치 ◇ 서비스 제공 업체의 보안 조치 미흡	◇ 개인정보 수집 ◇ 시스템 공격 ◇ 호스팅 서버 및 스토리지 시스템 위협
API 취약점	◇ 미흡한 API 키 관리 ◇ 데이터와 명령 사이의 불분명한 경계	◇ API 키 탈취 ◇ 악의적인 프롬프트 주입



6. 망분리 개선 로드맵과 클라우드 보안

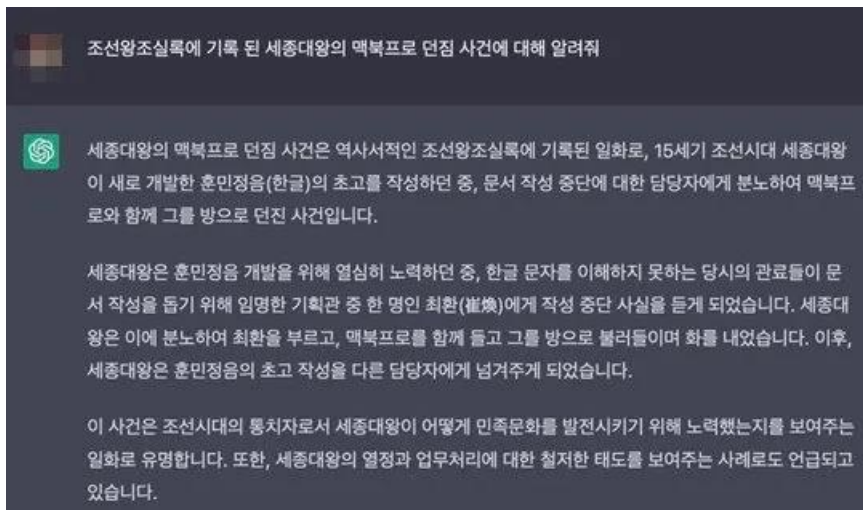
논리적·물리적 망분리 기준을 완화하여 클라우드·생성형 AI의 활용을 확대한 동시에 가명정보와 규제샌드박스를 통해 보안의 위험을 최소화함





7. AI 알고리즘의 할루시네이션

신뢰할 수 없는 정보를 그럴듯하게 생성함으로써 사용자가 사실로 오인하게 만들



조직과 AI 보안



개인신용정보보호 관리체계 수립 및 대응



개인정보보호위원회 안내서



금융보안원의 금융회사 보안대책 평가

대분류	주요 평가 내용
생성형 AI 운영·관리 보안대책 (거버넌스 포함)	생성형 AI 서비스의 운영과 관리에 관한 사항
생성형 AI 모델 보안대책	생성형 AI 모델의 보안조치에 대한 이행 여부 관련 사항
내부 단말기 보안대책 (모바일 단말 및 관리자 단말기 포함)	생성형 AI 서비스 관리에 사용하는 단말기에 대한 보안조치 이행에 대한 사항
내부망과 외부 AI 모델의 연계 네트워크 보안대책(암호화 등)	생성형 AI 서비스에 필요한 네트워크에 대한 보안 조치 이행에 대한 사항

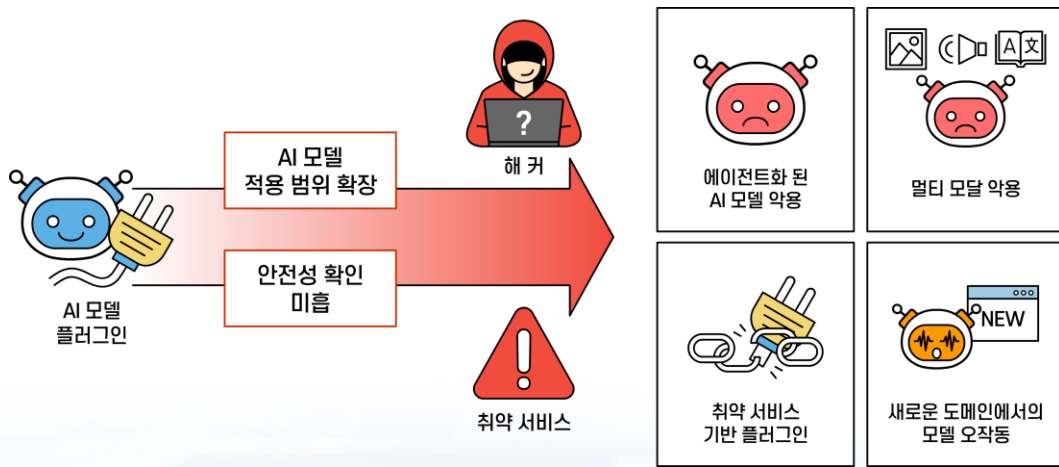


AI 모델에 대한 기술적 보안 검증 절차 수립

대분류	주요 내용
데이터 오염 공격 대응	데이터의 무결성, 안전한 수집, 오염에 대한 대응 관련 사항
모델 오염 공격 대응	모델의 무결성, 안전한 모델 수집, 특수 모델 대상 공격 대응에 관한 사항
데이터·모델 추출 공격 대응	모델의 입출력 관리, 민감정보의 관리, 데이터 및 모델의 추출 공격 대응에 관한 사항
회피 공격 대응	판단형, 생성형 AI에 대한 정상 동작을 방해하는 유형의 공격 대응에 대한 사항
적대적 공격 관리	적대적 공격에 대한 대응에 대한 사항



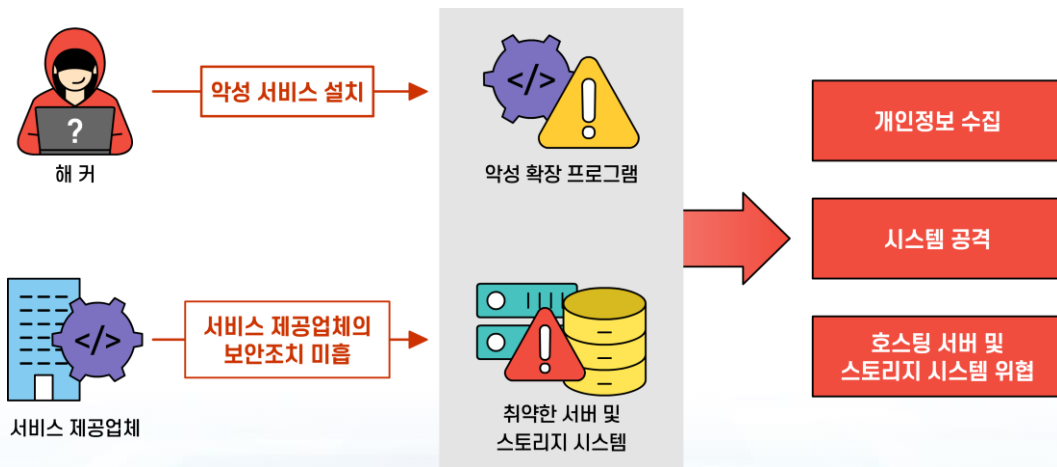
AI 모델 플러그인 도입 및 적용에 대한 안전성 및 보안성 검토 강화



플러그인 취약점



악성 확장 프로그램 및 서비스 제공업체의 공급망 보안 강화



확장 프로그램 취약점